



Universidad de Ingeniería y Tecnología

DS3031 – ÉTICA Y SEGURIDAD DE LOS DATOS

PROYECTO PARCIAL

Sistema seguro de apoyo a campañas bancarias con privacidad de datos

Profesor: Pazos Ortiz, Jose Carlos

Estudiantes	Código
Mora Huamanchay, Angel Obed	202010031
Surco Vergara, Maria Fernanda	202110358
Villarreal Falcon, Mishelle Stephany	202010177

20 de Mayo de 2026

Índice

1. Introducción	3
2. Descripción del Problema	4
3. Caso de Negocio Propuesto	4
4. Objetivos del Proyecto	5
5. KPIs y OKRs del Caso de Negocio	7
6. Descripción del Dataset Base	8
7. Datos Sintéticos Complementarios	9
8. Marco Legal y Normativo Aplicable	13
9. Bloque III — Diseño de la Solución	15
9.1. Diseño funcional del sistema	15
9.1.1. Actores del sistema	16
9.1.2. Flujos funcionales principales	16
9.1.3. Casos de uso principales	16
9.2. Arquitectura propuesta	16
9.2.1. Componentes de la arquitectura	16
9.2.2. Diagrama lógico de arquitectura	17
9.2.3. Justificación del stack tecnológico	17
9.3. Diseño de la base de datos	17
9.3.1. Entidades principales	17
9.3.2. Modelo relacional propuesto	20
9.3.3. Clasificación de columnas sensibles	20
9.3.4. Esquema SQL base	20
9.4. Requerimientos funcionales	23
10. Bloque IV — Seguridad y privacidad	23
10.1. Protección de datos en reposo	24
10.1.1. Cifrado de información sensible	24
10.1.2. Hashing de contraseñas	24
10.1.3. Política de respaldos	24
10.2. Protección de datos en tránsito	24

10.3. Control de accesos basado en roles	25
10.4. Gestión del consentimiento	25
10.5. Registros de auditoría	25
10.6. Plan de respuesta ante incidentes	26
10.7. Estrategias de uso seguro	26
10.7.1. Política de contraseñas	26
10.7.2. Capacitación del personal	26
10.8. Recomendaciones futuras	26
11. Bloque V — Próximos pasos	27
11.1. Implementación del prototipo	27
11.2. Pruebas de seguridad	27
11.3. Documentación final	28
11.4. Referencias	28
11.5. Anexos	29

1. Introducción

En el sector financiero, las campañas de marketing y telemarketing son utilizadas para ofrecer productos como depósitos a plazo, préstamos, tarjetas u otros servicios bancarios. Sin embargo, en muchos casos estas campañas se realizan de forma masiva, contactando a una gran cantidad de clientes sin considerar si realmente presentan interés o una alta probabilidad de aceptar el producto ofrecido. Esta práctica puede generar costos operativos elevados, baja eficiencia comercial, pérdida de tiempo para los equipos de atención y una experiencia poco adecuada para los clientes que reciben comunicaciones no relevantes.

A partir de esta problemática, el presente proyecto propone el diseño de un sistema seguro de apoyo a campañas bancarias, orientado a mostrar únicamente los perfiles de clientes más adecuados según el tipo de campaña seleccionada. Para ello, se utilizará como dataset base el Bank Marketing Dataset, disponible en Kaggle. Este conjunto de datos contiene información demográfica, financiera y de contacto asociada a campañas bancarias, permitiendo analizar la propensión de los clientes a contratar un depósito a plazo.

Con el fin de simular un entorno bancario más realista, el dataset base será complementado con datos sintéticos. Estos datos incluirán información ficticia como identificadores de clientes, números de contacto, correos electrónicos, consentimiento para campañas, estado de opt-in y opt-out (señales de consentimiento, positivo o negativo), usuarios internos, roles, permisos y registros de auditoría. Esta ampliación permitirá representar de mejor manera cómo funcionaría un sistema real donde no solo se analizan datos para una campaña, sino que también se controla quién puede acceder a la información, qué datos puede visualizar y bajo qué condiciones puede utilizarlos.

El sistema propuesto contempla distintos tipos de usuarios, como administradores, supervisores, analistas de marketing y teleoperadores. Cada rol tendrá permisos específicos, de modo que la información visible sea limitada según sus funciones. Por ejemplo, un teleoperador solo debería visualizar los clientes asignados para contacto, mientras que un supervisor podría acceder a métricas generales de campaña y un administrador tendría la capacidad de gestionar usuarios, roles y registros de auditoría. De esta forma, se aplica el principio de mínimo privilegio y se reduce la exposición innecesaria de datos personales.

Desde el enfoque de ética y seguridad de datos, **el proyecto busca equilibrar el valor de negocio con la protección de la información.** Por un lado, la solución permitirá mejorar indicadores como la tasa de conversión, **la reducción de llamadas innecesarias y el costo por adquisición de clientes.** Por otro lado, se propondrán medidas de seguridad y privacidad como control de accesos por roles, cifrado de datos, hashing de contraseñas, uso de certificados digitales, registros de auditoría, backups, gestión de consentimiento y un plan básico de respuesta ante incidentes.

En ese sentido, este proyecto no se limita a analizar un dataset bancario, sino que plantea una solución integral donde los datos son utilizados de manera responsable, segura y orientada a un caso de negocio concreto. La propuesta busca demostrar cómo una institución financiera podría optimizar sus campañas comerciales sin exponer innecesariamente la información de sus clientes, incorporando principios de privacidad por diseño, minimización de datos y trazabilidad en el uso de la información.

2. Descripción del Problema

Las campañas de marketing de productos bancarios de forma masiva generan diversos problemas que pueden agruparse en cuatro dimensiones, resumidas en la Tabla 1.

Dimensión	Descripción del problema
Costos operativos	Se invierte tiempo, infraestructura y recursos humanos en contactar clientes con baja probabilidad de conversión, lo que eleva el costo por adquisición.
Eficiencia comercial	Los teleoperadores y analistas no priorizan necesariamente los perfiles más adecuados, lo que reduce la productividad del equipo y dificulta el cumplimiento de metas.
Experiencia del cliente	Los clientes pueden recibir llamadas o comunicaciones no relevantes, repetitivas o no solicitadas, lo que deteriora la percepción de la marca y aumenta la tasa de opt-out.
Ética, privacidad y seguridad	Las campañas trabajan con información demográfica, financiera y de contacto sensible. Sin controles de acceso adecuados, existe el riesgo de que usuarios internos accedan a datos que no requieren para sus funciones.

Cuadro 1: Dimensiones del problema abordado por el proyecto.

Además del problema comercial, existe una preocupación importante relacionada con la **ética, privacidad y seguridad de los datos**. Las campañas bancarias suelen trabajar con información demográfica, financiera y de contacto de los clientes, como edad, ocupación, estado civil, balance financiero, historial de contacto y respuesta a campañas anteriores. Este tipo de información debe ser tratada con cuidado, ya que no todos los usuarios internos deberían tener acceso al mismo nivel de detalle.

La problemática principal que aborda este proyecto es la necesidad de **optimizar las campañas bancarias mostrando únicamente los perfiles más adecuados según el tipo de campaña, y al mismo tiempo proteger la información de los clientes mediante controles de seguridad, privacidad y trazabilidad**. De esta manera, se busca evitar tanto el contacto indiscriminado de clientes como la exposición innecesaria de datos sensibles dentro del sistema.

3. Caso de Negocio Propuesto

El caso de negocio se sitúa en el área de marketing de una entidad bancaria que tiene como objetivo mejorar los resultados de sus campañas comerciales, especialmente aquellas orientadas a la contratación de depósitos a plazo. En este contexto, el equipo de marketing necesita identificar qué clientes tienen mayor probabilidad de aceptar una oferta, con el fin de priorizar sus esfuerzos, reducir llamadas innecesarias y cumplir sus metas de conversión de manera más eficiente.

Sin embargo, esta necesidad comercial entra en contacto directo con los lineamientos internos de seguridad y privacidad del banco. El equipo de ciberseguridad advierte que no es adecuado exponer toda la información de los clientes a cualquier usuario del sistema, ni permitir que los datos sean utilizados sin controles claros. Variables como información financiera, historial de

contacto, datos demográficos y canales de comunicación deben tratarse bajo políticas de acceso, trazabilidad y consentimiento.

Ante esta situación, el área de data y gobernanza participa como un equipo articulador entre marketing y ciberseguridad. Su rol es diseñar una solución que permita aprovechar los datos para mejorar la efectividad de las campañas, pero respetando principios de minimización de datos, control de accesos y uso responsable de la información.

Para reforzar el componente de privacidad, el sistema considerará el estado de consentimiento del cliente, incluyendo mecanismos de opt-in y opt-out. Esto significa que un cliente solo podrá ser considerado para una campaña si ha autorizado recibir comunicaciones comerciales, y será excluido automáticamente si ha solicitado no ser contactado. Así, el proyecto busca evitar prácticas de contacto indiscriminado y promover un uso más ético de los datos.

Stakeholders del proyecto

La Tabla 2 resume los principales actores involucrados, su interés en el proyecto y el tipo de valor que esperan obtener de la solución propuesta.

Stakeholder	Interés principal	Valor esperado
Área de Marketing	Aumentar la tasa de conversión y cumplir metas comerciales.	Listas de clientes priorizadas y métricas de campaña confiables.
Área de Ciberseguridad	Proteger la información de los clientes y cumplir con la normativa.	Controles de acceso, auditoría y cifrado coherentes con la política interna.
Área de Data y Gobernanza	Garantizar uso responsable, calidad y trazabilidad de los datos.	Modelo de datos documentado, gestión de consentimiento y minimización.
Teleoperadores y supervisores	Contar con información clara para gestionar contactos efectivos.	Interfaz con datos relevantes según rol, sin exposición innecesaria.
Clientes finales del banco	Recibir comunicaciones pertinentes y proteger su información personal.	Respeto al consentimiento, privacidad y derecho a no ser contactado.
Autoridad de Protección de Datos	Verificar cumplimiento de la Ley N.º 29733.	Evidencia documental de controles, trazabilidad y respuesta ante incidentes.

Cuadro 2: Stakeholders del proyecto e intereses asociados.

4. Objetivos del Proyecto

Objetivo general

Diseñar un sistema seguro de apoyo a campañas bancarias que permita identificar y priorizar los perfiles de clientes más adecuados según el tipo de campaña, aplicando principios de privacidad

por diseño, minimización de datos, control de accesos por roles y trazabilidad, de forma que se mejore la efectividad comercial sin comprometer la protección de la información personal de los clientes.

Objetivos específicos

1. **Analizar** el *Bank Marketing Dataset* y complementarlo con datos sintéticos coherentes que permitan representar un entorno bancario realista, incluyendo identificadores de clientes, consentimientos, usuarios internos, roles y registros de auditoría.
2. **Diseñar** la arquitectura funcional y técnica del sistema, contemplando frontend, backend, base de datos y servicios auxiliares de seguridad.
3. **Definir** un modelo de control de accesos basado en roles (RBAC) que aplique el principio de mínimo privilegio para administradores, supervisores, analistas de marketing y teleoperadores.
4. **Implementar** medidas de protección de datos en reposo y en tránsito, incluyendo cifrado simétrico, hashing de contraseñas y uso de certificados digitales sobre TLS.
5. **Establecer** mecanismos de auditoría y trazabilidad mediante registros (logs) que permitan reconstruir quién accedió a qué información, cuándo y con qué resultado.
6. **Incorporar** la gestión del consentimiento del cliente (opt-in y opt-out) como criterio obligatorio para la inclusión en campañas.
7. **Formular** un plan básico de respuesta ante incidentes de seguridad y un conjunto de recomendaciones de mejora futura alineadas con estándares internacionales y la normativa peruana.

Alcance

El proyecto contempla el diseño y prototipo funcional del sistema descrito, incluyendo:

- Modelo de base de datos relacional con tablas para clientes, campañas, usuarios, roles, permisos, consentimientos y logs de auditoría.
- Backend con autenticación, autorización por roles y endpoints de consulta filtrada.
- Frontend mínimo orientado a demostrar el flujo de uso por cada rol.
- Generación de certificados digitales autofirmados para habilitar TLS.
- Documentación de políticas, procedimientos y plan de respuesta ante incidentes.

Fuera de alcance

Quedan explícitamente fuera del alcance de esta primera entrega:

- El entrenamiento y despliegue productivo de modelos de *machine learning* para predicción de propensión; se asume un sistema de *scoring* simulado.

- La integración con sistemas reales del banco (CRM, core bancario, marcadores telefónicos).
- La obtención de certificados emitidos por una Autoridad Certificadora pública.
- La implementación de un SIEM o de capacidades avanzadas de detección, las cuales se incluyen como recomendaciones futuras.

5. KPIs y OKRs del Caso de Negocio

Con el objetivo de medir objetivamente el valor generado por el sistema, se definen indicadores clave de desempeño (KPIs) y objetivos con resultados clave (OKRs). Los KPIs cubren tanto la dimensión comercial como la dimensión ética y de seguridad, en línea con el espíritu del proyecto.

Indicadores Clave de Desempeño (KPIs)

KPI	Fórmula	Línea base	Meta	Frecuencia
Tasa de conversión de campaña	$\frac{\text{Clientes que aceptan llamadas}}{\text{Clientes contactados}} \times 100$	11 %	13 % (+20 %)	Por campaña
Reducción de llamadas no efectivas	$\frac{\text{Llamadas sin conversión}}{\text{Total de llamadas}} \times 100$	89 %	62 % (-30 %)	Mensual
Costo por adquisición (CPA)	$\frac{\text{Costo total de campaña}}{\text{Clientes adquiridos}}$	Referencia	-15 %	Por campaña
Tasa de opt-out post-campaña	$\frac{\text{Opt-outs nuevos}}{\text{Clientes contactados}} \times 100$	N/D	< 2 %	Mensual
Cobertura de consentimiento	$\frac{\text{Clientes con consentimiento}}{\text{Registrados}} \times 100$	N/D	95 %	Mensual
Incidentes de seguridad detectados	Conteo absoluto de incidentes	N/D	Tendencia decreciente	Mensual
Tiempo de respuesta ante incidentes	Tiempo entre detección y contención	N/D	< 4 horas (P1)	Por incidente

Cuadro 3: KPIs del caso de negocio y métricas de seguridad asociadas.

Los dos últimos KPIs (incidentes detectados y tiempo de respuesta) se incluyen explícitamente como *indicadores de salud de seguridad*, reconociendo que la efectividad comercial sin protección de datos no constituye un resultado aceptable bajo el marco del curso ni bajo la Ley N.º 29733.

Objetivos y Resultados Clave (OKRs)

Objetivo 1. Incrementar la efectividad de las campañas de depósitos a plazo durante el periodo evaluado.

- **KR 1.1.** Elevar la tasa de conversión de campaña de 11 % a 13 %.
- **KR 1.2.** Reducir en 30 % el volumen de llamadas no efectivas frente al periodo anterior.
- **KR 1.3.** Disminuir en 15 % el costo por adquisición (CPA).

Objetivo 2. Garantizar el uso ético y seguro de los datos de clientes en las campañas bancarias.

- **KR 2.1.** Alcanzar una cobertura de consentimiento registrado superior al 95 % del universo de clientes utilizado en campañas.
- **KR 2.2.** Mantener la tasa de opt-out post-campaña por debajo del 2 %.
- **KR 2.3.** Lograr que el 100 % de los accesos a información sensible queden registrados en logs de auditoría y revisados mensualmente.

6. Descripción del Dataset Base

El dataset base seleccionado para este proyecto es el *Bank Marketing Dataset*, derivado del conjunto publicado originalmente por Moro, Cortez y Rita (2014) en el *UCI Machine Learning Repository*. El conjunto de datos contiene información asociada a campañas de marketing directo (llamadas telefónicas) realizadas por una entidad bancaria portuguesa, donde la variable objetivo indica si el cliente terminó suscribiendo o no un depósito a plazo.

Para el presente proyecto se utiliza la versión disponible en Kaggle como `bank.csv`, que contiene **11 162 registros** y **17 atributos** (16 variables de entrada y 1 variable objetivo denominada `deposit`). Esta versión es una variante balanceada del dataset original ampliamente utilizada en la comunidad académica, en la que las clases positiva y negativa se encuentran representadas en proporciones similares, lo que la hace especialmente útil para fines de modelado predictivo y demostración de soluciones.

Caracterización general del dataset

El análisis exploratorio inicial arroja las siguientes propiedades estructurales del dataset:

- **Volumen.** 11 162 registros, suficientes para representar un escenario realista de campaña y para entrenar modelos de *scoring* en etapas futuras del proyecto.
- **Integridad.** El dataset no presenta valores nulos en ninguna de sus 17 columnas, lo que simplifica los procesos de carga y validación.
- **Balanceo de clases.** La variable objetivo `deposit` presenta una distribución cercana al 50/50 (aproximadamente 47,38 % “yes” y 52,62 % “no”).
- **Diversidad demográfica.** La edad de los clientes oscila entre 18 y 95 años, con una media cercana a los 41 años, representando un universo de clientes bancarios amplio y realista.
- **Rango financiero.** La variable `balance` (saldo promedio anual) incluye valores negativos (mínimo -6 847 EUR) y positivos hasta 81 204 EUR, evidenciando clientes en sobregiro y clientes con alto poder adquisitivo en el mismo conjunto.

Nota sobre el balanceo del dataset y su efecto en los KPIs

Es importante señalar que la versión utilizada de este dataset ha sido **balanceada artificialmente** con fines de modelado, por lo que la tasa observada de aceptación del 47,38 % no representa la tasa real de conversión de una campaña bancaria. La literatura especializada y el dataset original completo (45 211 registros, no balanceado) reportan una tasa real de conversión cercana al 11–12 % Moro et al., 2014. Por tal motivo, los KPIs definidos en el Bloque I (línea base de 11 % y meta de 13 %) se mantienen sobre la base realista del entorno bancario y *no* sobre la distribución artificial del dataset, lo cual permite plantear objetivos consistentes con la operación real de una entidad financiera.

Atributos del dataset base

La Tabla 4 presenta los 17 atributos del dataset junto con su tipo de dato y una clasificación inicial de sensibilidad. Esta clasificación se aplica con el criterio de la Ley N.º 29733 y su reglamento vigente (D.S. N.º 016-2024-JUS), distinguiendo entre datos personales, datos financieros y datos operacionales.

Consideraciones técnicas relevantes

Durante el análisis preliminar del dataset se identifican aspectos que condicionan tanto el modelado como el manejo seguro de la información:

- **Balanceo artificial.** Como se indicó, la distribución cercana a 50/50 de la variable `deposit` no refleja la realidad operativa. Los KPIs del proyecto se calibran sobre la línea base realista del 11 %.
- **Variable duration.** Aunque es altamente predictiva, su valor solo se conoce *después* de realizar la llamada, por lo que no puede usarse en un escenario realista de priorización previa al contacto. Se mantiene en el dataset únicamente con fines descriptivos.
- **Codificación de pdays.** El valor -1 no representa una cantidad negativa de días, sino que codifica la situación “cliente nunca contactado en campañas anteriores”. Aproximadamente el 75 % de los registros se encuentran en esta condición. Es necesario tratarlo como una categoría especial al modelar.
- **Atributos sensibles.** Variables como `age`, `job`, `marital`, `balance`, `default`, `housing` y `loan` constituyen información personal y financiera bajo la normativa peruana, por lo que su acceso debe estar restringido por rol y registrado en logs de auditoría.
- **Ausencia de identificadores directos.** El dataset original no contiene identificadores únicos, nombres, números de documento ni datos de contacto. Esta limitación motiva la generación de datos sintéticos complementarios descrita en la siguiente sección.

7. Datos Sintéticos Complementarios

El dataset base, si bien resulta adecuado para análisis predictivo, no contiene los elementos necesarios para representar un sistema bancario real con controles de seguridad y privacidad.

#	Atributo	Tipo	Descripción	Sensibilidad
1	age	Numérico	Edad del cliente (rango 18–95 años).	Dato personal
2	job	Categorico (12)	Tipo de ocupación: admin., blue-collar, entrepreneur, housemaid, management, retired, self-employed, services, student, technician, unemployed, unknown.	Dato personal
3	marital	Categorico (3)	Estado civil: divorced, married, single.	Dato personal
4	education	Categorico (4)	Nivel educativo: primary, secondary, tertiary, unknown.	Dato personal
5	default	Binario	Indica si el cliente tiene crédito en mora (yes/no).	Dato financiero
6	balance	Numérico	Saldo promedio anual en euros (rango –6 847 a 81 204).	Dato financiero
7	housing	Binario	Indica si tiene un préstamo hipotecario (yes/no).	Dato financiero
8	loan	Binario	Indica si tiene un préstamo personal (yes/no).	Dato financiero
9	contact	Categorico (3)	Canal de contacto: celular, telephone, unknown.	Operacional
10	day	Numérico	Día del mes del último contacto.	Operacional
11	month	Categorico (12)	Mes del último contacto (jan–dec).	Operacional
12	duration	Numérico	Duración del último contacto en segundos.	Operacional
13	campaign	Numérico	Número de contactos durante la campaña actual.	Operacional
14	pdays	Numérico	Días desde el último contacto previo (–1 indica nunca contactado).	Operacional
15	previous	Numérico	Número de contactos antes de la campaña actual.	Operacional
16	poutcome	Categorico (4)	Resultado de la campaña anterior: failure, other, success, unknown.	Operacional
17	deposit	Binario	Variable objetivo: el cliente suscribió un depósito a plazo (yes/no).	Operacional

Cuadro 4: Atributos del Bank Marketing Dataset y clasificación de sensibilidad.

En particular, carece de identificadores únicos de cliente, datos de contacto, registros de consentimiento, usuarios internos del sistema, roles, permisos y registros de auditoría. Por esta razón, el proyecto complementa la información con datos sintéticos generados específicamente para reproducir un entorno operativo realista.

Justificación del uso de datos sintéticos

El uso de datos sintéticos se justifica por tres razones principales. Primero, permite **simular información de contacto y consentimiento** sin recurrir a datos reales de personas, evitando cualquier riesgo de exposición de información personal verdadera. Segundo, posibilita **construir y probar los controles de seguridad** (RBAC, auditoría, cifrado, gestión de consentimiento) con escenarios completos y trazables. Tercero, facilita la **reproducibilidad académica** del proyecto, ya que los datos pueden regenerarse mediante semillas (*seeds*) controladas sin depender de fuentes externas.

Herramienta y enfoque de generación

La generación se realiza mediante la librería **Faker** de Python, complementada con módulos estándar (`random`, `uuid`, `datetime`) y `hashlib` para los hashes de contraseñas en el caso de los usuarios internos. Se utiliza una semilla fija (`Faker.seed(42)`) para garantizar la reproducibilidad de los datos generados. La localización del Faker se establece en español de Perú (`es_PE`) para que los nombres, direcciones y números telefónicos guarden coherencia con el contexto local del proyecto.

Estructuras generadas

La Tabla 5 resume las estructuras sintéticas generadas, su propósito y los principales atributos que contienen. Estas tablas se vincularán al dataset base mediante el campo `cliente_id`, generado al asignar un identificador único a cada uno de los 11 162 registros originales.

Ejemplo de generación

A modo ilustrativo, el siguiente fragmento de código muestra cómo se generan las filas sintéticas de la entidad `Cliente` a partir del dataset base:

```
from faker import Faker
import pandas as pd
import uuid

fake = Faker("es_PE")
Faker.seed(42)

df_base = pd.read_csv("bank.csv") # 11,162 registros
n = len(df_base)

df_clientes = pd.DataFrame({
    "cliente_id": [str(uuid.uuid4()) for _ in range(n)],
    "nombre": [fake.name() for _ in range(n)],
    "dni": [fake.unique.bothify("#####") for _ in range(n)],
    "email": [fake.unique.email() for _ in range(n)],
    "telefono": [fake.phone_number() for _ in range(n)],
    "direccion": [fake.address() for _ in range(n)],
})
```

Entidad	Propósito	Atributos principales
Cliente	Asociar un identificador único a cada registro del dataset base.	cliente_id, nombre, dni, email, telefono, direccion.
Consentimiento	Registrar la voluntad del cliente respecto a comunicaciones comerciales.	consentimiento_id, cliente_id, estado (opt-in / opt-out / no informado), canal, fecha_registro, fecha_actualizacion.
Usuario interno	Representar al personal del banco que utiliza el sistema.	usuario_id, username, nombre_completo, email_corporativo, password_hash, rol_id, activo.
Rol	Definir los perfiles funcionales del sistema.	rol_id, nombre (administrador, supervisor, analista, teleoperador), descripcion.
Permiso	Definir las operaciones autorizadas.	permiso_id, nombre, recurso, accion.
Rol-Permiso	Asociar permisos a roles (RBAC).	rol_id, permiso_id.
Campaña	Representar una campaña comercial.	campania_id, nombre, producto, fecha_inicio, fecha_fin, estado.
Asignación	Vincular un cliente a una campaña y un teleoperador.	asignacion_id, cliente_id, campania_id, usuario_id, estado_contacto.
Log de auditoría	Registrar las acciones realizadas en el sistema.	log_id, usuario_id, accion, recurso, timestamp, ip_origen, resultado.

Cuadro 5: Estructuras sintéticas complementarias al dataset base.

De forma análoga se generan las demás entidades. Para la tabla de **Consentimiento**, los estados se asignan con probabilidades controladas (por ejemplo, 70 % opt-in, 20 % no informado, 10 % opt-out) de modo que se obtengan escenarios variados para probar la exclusión automática en campañas.

Garantías sobre los datos sintéticos

Los datos sintéticos cumplen con las siguientes propiedades, alineadas con el principio de minimización y la privacidad por diseño:

- No corresponden a personas reales y no pueden ser vinculados a individuos identificables.
- Se generan localmente y se almacenan en la base de datos del proyecto, sin compartirse fuera del entorno de desarrollo.
- Los DNI, emails y teléfonos son ficticios y siguen formatos válidos solo para fines de prueba.
- Las contraseñas de los usuarios internos se almacenan únicamente como hash mediante un algoritmo de *key derivation* (ver Bloque IV), nunca en texto plano.

8. Marco Legal y Normativo Aplicable

El tratamiento de los datos contemplado en este proyecto se enmarca en la normativa peruana de protección de datos personales, complementada por estándares internacionales reconocidos. A continuación se describen los instrumentos aplicables y su relación con las decisiones de diseño del sistema.

Ley N.º 29733, Ley de Protección de Datos Personales

La Ley N.º 29733, promulgada en 2011, constituye el marco legal principal en Perú para el tratamiento de datos personales. Su objeto es garantizar el derecho fundamental a la protección de los datos personales reconocido en el artículo 2, numeral 6 de la Constitución Política del Perú. La ley aplica a todo banco de datos personales, ya sea administrado por entidades públicas o privadas, cuyo tratamiento se realice en territorio peruano.

Reglamento vigente: D.S. N.º 016-2024-JUS

El reglamento vigente fue aprobado mediante el Decreto Supremo N.º 016-2024-JUS, publicado el 30 de noviembre de 2024 y con entrada en vigor el 29 de marzo de 2025. Este nuevo reglamento deroga al D.S. N.º 003-2013-JUS y actualiza el marco normativo peruano para alinearlos con estándares internacionales como el Reglamento General de Protección de Datos (GDPR) europeo y la norma ISO/IEC 27001. Entre los cambios relevantes para este proyecto destacan:

- Ampliación de la definición de datos personales para incluir información de localización e identificación en línea.
- Reforzamiento de los derechos ARCO (acceso, rectificación, cancelación, oposición) y de los mecanismos de consentimiento.
- Mayor precisión sobre el régimen sancionador y las obligaciones de notificación de incidentes.
- Énfasis en principios como privacidad por diseño y por defecto, y responsabilidad proactiva (*accountability*).

Principios rectores y su aplicación al proyecto

La Tabla 6 relaciona los principios rectores de la Ley N.º 29733 con los controles técnicos y organizativos que el sistema implementa.

Autoridad Nacional de Protección de Datos Personales (ANPDP)

La ANPDP, dependiente del Ministerio de Justicia y Derechos Humanos, es el organismo encargado de supervisar el cumplimiento de la Ley N.º 29733. Entre sus facultades se encuentran la inscripción de bancos de datos personales, la atención de denuncias, la realización de inspecciones y la imposición de sanciones administrativas. El plan de respuesta ante incidentes del proyecto (Bloque IV) contempla la notificación a esta autoridad en caso de fugas o brechas de datos personales, conforme a los plazos establecidos por el reglamento vigente.

Principio	Descripción	Aplicación en el sistema
Legalidad	El tratamiento debe realizarse conforme a la ley, prohibiendo medios fraudulentos.	Los datos sintéticos se generan localmente y el dataset base se utiliza con fines académicos.
Consentimiento	El tratamiento requiere el consentimiento del titular.	Tabla de consentimiento con estados opt-in / opt-out y exclusión automática en campañas.
Finalidad	Los datos se recolectan para una finalidad determinada, explícita y lícita.	La finalidad declarada es la priorización ética de clientes para campañas de depósitos a plazo.
Proporcionalidad	El tratamiento debe ser adecuado, relevante y no excesivo.	Cada rol accede únicamente a los atributos necesarios para sus funciones (mínimo privilegio).
Calidad	Los datos deben ser veraces, exactos y actualizados.	Procedimientos de actualización de consentimiento y verificación periódica de registros.
Seguridad	Se deben adoptar medidas técnicas y organizativas adecuadas.	Cifrado en reposo y tránsito, hashing, RBAC, certificados digitales, backups (Bloque IV).
Disposición de recurso	El titular debe poder ejercer sus derechos.	El sistema contempla operaciones de consulta, rectificación y eliminación lógica de datos.
Nivel de protección adecuado	En transferencias internacionales se debe garantizar protección equiparable.	No se realizan transferencias internacionales en el alcance del proyecto.

Cuadro 6: Principios de la Ley N.º 29733 y su aplicación en el sistema.

Estándares internacionales considerados

Como complemento al marco legal peruano, el diseño del sistema toma referencia de los siguientes estándares internacionales:

- **ISO/IEC 27001.** Sistema de gestión de seguridad de la información (SGSI); orienta la definición de controles técnicos y organizativos.
- **ISO/IEC 27701.** Extensión del 27001 enfocada en la gestión de la privacidad de la información.
- **NIST SP 800-53.** Catálogo de controles de seguridad y privacidad utilizado como referencia para el diseño de RBAC, auditoría y respuesta a incidentes.
- **NIST SP 800-61.** Guía de manejo de incidentes de seguridad informática, usada como base del plan de respuesta del Bloque IV.
- **OWASP Top 10.** Considerado para el desarrollo seguro del backend y frontend del prototipo.

La Tabla 7 consolida el mapeo entre los principales requerimientos normativos y los controles técnicos del sistema, mostrando que cada exigencia regulatoria tiene un mecanismo concreto que la respalda.

Requerimiento normativo	Norma de origen	Control técnico u organizativo
Consentimiento del titular	Ley 29733, Art. 5	Tabla de consentimiento, opt-in/opt-out, exclusión automática.
Confidencialidad de la información	Ley 29733, Art. 17; ISO 27001	Cifrado AES en reposo y TLS en tránsito; control de accesos RBAC.
Integridad de los datos	ISO 27001; NIST 800-53	Hashing, restricciones de integridad referencial, logs inmutables.
Trazabilidad	D.S. 016-2024-JUS; ISO 27001	Logs de auditoría con usuario, acción, recurso, IP y timestamp.
Disponibilidad y recuperación	ISO 27001 (A.17)	Backups periódicos cifrados y procedimiento de restauración.
Notificación de incidentes	D.S. 016-2024-JUS	Plan de respuesta a incidentes con notificación a la ANPDP.
Privacidad por diseño	D.S. 016-2024-JUS	Minimización, separación de PII, mínimo privilegio desde el diseño.

Cuadro 7: Mapeo entre requerimientos normativos y controles del sistema.

9. Bloque III — Diseño de la Solución

El presente bloque desarrolla el diseño funcional y técnico del sistema seguro de apoyo a campañas bancarias. La solución propuesta busca integrar el valor comercial del análisis de datos con controles de privacidad, seguridad y trazabilidad desde el diseño. Para ello, se plantea una arquitectura modular compuesta por una interfaz web, una API backend, una base de datos relacional y servicios auxiliares orientados a auditoría, cifrado, respaldo y gestión de certificados.

El diseño se construye sobre tres principios principales. Primero, el principio de mínimo privilegio, de modo que cada usuario acceda únicamente a la información necesaria para cumplir sus funciones. Segundo, la privacidad por diseño, incorporando desde el modelo de datos la gestión de consentimiento, la separación de información sensible y el registro de accesos. Tercero, la trazabilidad operativa, permitiendo reconstruir las acciones realizadas sobre clientes, campañas, usuarios y datos sensibles.

9.1. Diseño funcional del sistema

El sistema propuesto permite que una entidad bancaria gestione campañas comerciales de manera segmentada, segura y trazable. En lugar de exponer todo el universo de clientes a todos los usuarios internos, la plataforma organiza el acceso según roles, permisos y reglas de negocio asociadas al consentimiento del cliente.

Desde el punto de vista funcional, la solución cubre el ciclo principal de una campaña bancaria: autenticación del usuario interno, selección de campaña, consulta de clientes elegibles, asignación de clientes a teleoperadores, registro del resultado del contacto, actualización del estado de consentimiento y generación de métricas agregadas para supervisión.

9.1.1. Actores del sistema

La Tabla 8 presenta los actores principales del sistema, sus responsabilidades y el nivel de acceso esperado.

9.1.2. Flujos funcionales principales

El sistema se organiza alrededor de cinco flujos funcionales principales:

1. **Inicio de sesión y autorización:** el usuario interno ingresa sus credenciales. El backend valida la identidad, genera un token de sesión y carga los permisos asociados al rol del usuario.
2. **Selección de campaña:** el supervisor o analista selecciona una campaña activa, por ejemplo una campaña de depósitos a plazo. El sistema recupera los criterios asociados a dicha campaña y prepara la consulta de clientes elegibles.
3. **Consulta de clientes elegibles:** el sistema filtra los clientes según criterios comerciales, estado de consentimiento y reglas de seguridad. Solo se consideran clientes con consentimiento válido y que no hayan solicitado opt-out.
4. **Asignación y contacto:** el supervisor asigna clientes a teleoperadores. Cada teleoperador visualiza únicamente su cartera asignada y registra el resultado del contacto.
5. **Auditoría y seguimiento:** toda acción relevante queda registrada en la tabla de auditoría, incluyendo inicio de sesión, consulta de clientes, modificación de consentimiento, asignaciones, exportaciones y cambios de permisos.

9.1.3. Casos de uso principales

La Tabla 9 resume los casos de uso más relevantes del sistema.

9.2. Arquitectura propuesta

La arquitectura propuesta sigue un enfoque por capas, separando presentación, lógica de negocio, persistencia y servicios auxiliares de seguridad. Esta separación permite reducir acoplamiento, mejorar la mantenibilidad del sistema y aplicar controles de seguridad en puntos específicos del flujo de información.

9.2.1. Componentes de la arquitectura

La solución contempla los siguientes componentes:

- **Frontend web:** interfaz utilizada por administradores, supervisores, analistas y teleoperadores. Puede implementarse con React, Vue o una tecnología equivalente.
- **Servidor web o proxy reverso:** componente encargado de recibir las solicitudes HTTPS, aplicar certificados TLS y redirigir el tráfico hacia la API backend. Para el prototipo se propone Nginx con certificados autofirmados generados mediante OpenSSL.

- **Backend/API:** servicio que implementa autenticación, autorización, reglas de negocio, validación de consentimiento, consulta de clientes elegibles, asignaciones y registro de resultados. Se propone FastAPI por su eficiencia, facilidad de documentación automática y compatibilidad con Python.
- **Base de datos relacional:** repositorio central del sistema. Se propone PostgreSQL por su robustez, soporte de restricciones relacionales, vistas, funciones, tipos de datos seguros y mecanismos de auditoría.
- **Servicio de auditoría:** módulo encargado de registrar eventos relevantes, tales como accesos a datos sensibles, cambios de permisos, actualizaciones de consentimiento, exportaciones y errores de autenticación.
- **Servicio de respaldo:** componente encargado de generar copias de seguridad periódicas y cifradas de la base de datos.
- **Gestión de claves y certificados:** para el prototipo se plantea una gestión local mediante variables de entorno y certificados autofirmados. En un entorno productivo, este componente debería migrar hacia un KMS o HSM gestionado.

9.2.2. Diagrama lógico de arquitectura

La Figura 1 representa el flujo general de comunicación entre componentes.

9.2.3. Justificación del stack tecnológico

La Tabla 10 resume el stack propuesto y su justificación.

9.3. Diseño de la base de datos

El modelo de base de datos propuesto busca representar tanto el dominio comercial de campañas bancarias como los elementos de seguridad requeridos para controlar el acceso a datos personales. Por ello, el diseño separa entidades de negocio, entidades de seguridad y entidades de auditoría.

9.3.1. Entidades principales

Las entidades consideradas son las siguientes:

- **Cliente:** representa al titular de los datos y se vincula con los atributos provenientes del Bank Marketing Dataset y los datos sintéticos complementarios.
- **Consentimiento:** registra el estado de autorización del cliente para recibir comunicaciones comerciales.
- **Campaña:** representa una campaña comercial, como una campaña de depósitos a plazo.
- **Asignación:** vincula clientes, campañas y teleoperadores.
- **Resultado de contacto:** registra el resultado de cada interacción realizada por un teleoperador.

Actor	Responsabilidad principal	Nivel de acceso esperado
Administrador	Gestionar usuarios internos, roles, permisos, parámetros del sistema y registros de auditoría.	Acceso administrativo a configuración, usuarios, roles y logs. No requiere visualizar todos los datos sensibles de clientes salvo casos justificados.
Supervisor	Monitorear el desempeño de campañas, revisar métricas agregadas y supervisar la actividad de teleoperadores.	Acceso a indicadores generales, resultados de campaña, asignaciones y reportes agregados.
Analista de marketing	Consultar segmentos recomendados, revisar clientes priorizados y evaluar el desempeño comercial de las campañas.	Acceso a perfiles priorizados y variables relevantes para segmentación, con datos sensibles minimizados o enmascarados cuando no sean necesarios.
Teleoperador	Contactar únicamente a los clientes asignados y registrar el resultado de cada interacción.	Acceso limitado a clientes asignados, datos de contacto necesarios y estado de consentimiento.
Cliente final	Titular de los datos personales y receptor potencial de comunicaciones comerciales.	No accede directamente al sistema interno, pero su consentimiento condiciona si puede ser contactado.

Cuadro 8: Actores del sistema y niveles de acceso esperados.

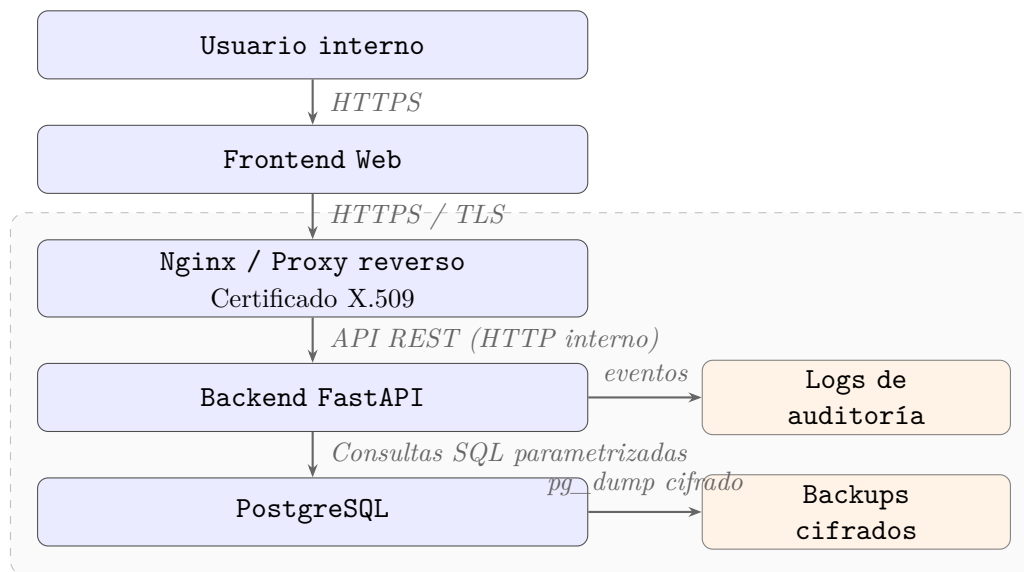


Figura 1: Arquitectura lógica propuesta del sistema.

ID	Actor	Caso de uso	Resultado esperado
CU-01	Usuario interno	Iniciar sesión en el sistema mediante credenciales válidas.	Sesión autenticada y permisos cargados según rol.
CU-02	Administrador	Crear, editar o desactivar usuarios internos.	Usuario registrado o actualizado con rol asignado.
CU-03	Administrador	Gestionar roles y permisos del sistema.	Matriz RBAC actualizada y registrada en auditoría.
CU-04	Analista de marketing	Consultar campañas activas y clientes priorizados.	Lista de clientes elegibles filtrada por campaña y consentimiento.
CU-05	Supervisor	Asignar clientes elegibles a teleoperadores.	Clientes distribuidos de forma controlada entre usuarios autorizados.
CU-06	Teleoperador	Visualizar clientes asignados para contacto.	Lista limitada a clientes bajo su responsabilidad.
CU-07	Teleoperador	Registrar resultado del contacto.	Resultado almacenado y vinculado a campaña, cliente y usuario.
CU-08	Supervisor	Consultar métricas agregadas de campaña.	Indicadores de conversión, llamadas efectivas y opt-out disponibles.
CU-09	Usuario autorizado	Actualizar estado de consentimiento del cliente.	Estado opt-in, opt-out o no informado actualizado con trazabilidad.
CU-10	Administrador/Supervisor	Revisar logs de auditoría.	Eventos críticos disponibles para revisión y control interno.

Cuadro 9: Casos de uso funcionales del sistema.

- **Usuario interno:** representa a los trabajadores del banco que acceden al sistema.
- **Rol:** define el perfil funcional del usuario.
- **Permiso:** define las acciones autorizadas sobre recursos específicos.
- **Rol-permiso:** tabla intermedia que implementa el modelo RBAC.
- **Log de auditoría:** registra eventos relevantes para trazabilidad y control.

9.3.2. Modelo relacional propuesto

La Tabla 11 resume las tablas principales del modelo.

9.3.3. Clasificación de columnas sensibles

Para aplicar privacidad por diseño, las columnas del modelo se clasifican según su nivel de sensibilidad. La Tabla 12 muestra el tratamiento propuesto.

9.3.4. Esquema SQL base

A continuación se presenta un esquema SQL simplificado de las tablas principales. Este diseño puede ampliarse en los anexos con restricciones adicionales, índices, vistas y funciones de auditoría.

```
CREATE TABLE rol (
    rol_id SERIAL PRIMARY KEY,
    nombre VARCHAR(50) NOT NULL UNIQUE,
    descripcion TEXT
);

CREATE TABLE permiso (
    permiso_id SERIAL PRIMARY KEY,
    nombre VARCHAR(100) NOT NULL UNIQUE,
    recurso VARCHAR(100) NOT NULL,
    accion VARCHAR(50) NOT NULL
);

CREATE TABLE rol_permiso (
    rol_id INT REFERENCES rol(rol_id),
    permiso_id INT REFERENCES permiso(permiso_id),
    PRIMARY KEY (rol_id, permiso_id)
);

CREATE TABLE usuario (
    usuario_id UUID PRIMARY KEY,
    username VARCHAR(50) NOT NULL UNIQUE,
    nombre_completo VARCHAR(120) NOT NULL,
    email_corporativo VARCHAR(120) NOT NULL UNIQUE,
    password_hash TEXT NOT NULL,
```

Capa	Tecnología propuesta	Justificación
Frontend	React	Permite construir interfaces modulares por rol, reutilizar componentes y separar vistas para administrador, supervisor, analista y teleoperador.
Backend/API	FastAPI	Facilita el desarrollo de endpoints seguros, validación de datos, documentación automática y conexión directa con librerías de Python para procesamiento de datos.
Base de datos	PostgreSQL	Permite modelado relacional robusto, restricciones de integridad, vistas seguras, transacciones y soporte para auditoría.
Servidor web	Nginx	Permite actuar como proxy reverso, centralizar TLS, redirigir tráfico y separar la exposición pública del backend.
Certificados	OpenSSL	Permite generar certificados X.509 auto-firmados para demostrar cifrado en tránsito dentro del alcance académico.
Hashing	Argon2id o bcrypt	Permite almacenar contraseñas de usuarios internos sin conservar valores en texto plano.
Auditoría	Tabla audit_log	Permite registrar eventos críticos para trazabilidad, investigación y cumplimiento.

Cuadro 10: Stack tecnológico propuesto y justificación.

Tabla	Clave principal	Descripción
cliente	cliente_id	Almacena datos sintéticos de identificación y atributos importados del dataset base.
consentimiento	consentimiento_id	Registra el estado opt-in, opt-out o no informado del cliente.
campania	campania_id	Define campañas comerciales y sus criterios principales.
usuario	usuario_id	Almacena usuarios internos, credenciales hasheadas y rol asignado.
rol	rol_id	Define perfiles de acceso: administrador, supervisor, analista y teleoperador.
permiso	permiso_id	Define acciones autorizadas sobre recursos.
rol_permiso	rol_id, permiso_id	Relaciona roles con permisos.
asignacion	asignacion_id	Vincula clientes elegibles con campañas y teleoperadores.
resultado_contacto	resultado_id	Registra el resultado de cada llamada o interacción.
audit_log	log_id	Almacena eventos auditable del sistema.

Cuadro 11: Tablas principales del modelo relacional propuesto.

```

    rol_id INT NOT NULL REFERENCES rol(rol_id),
    activo BOOLEAN DEFAULT TRUE,
    fecha_creacion TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);

```

```

CREATE TABLE cliente (
    cliente_id UUID PRIMARY KEY,
    nombre_cifrado TEXT,
    dni_cifrado TEXT,
    email_cifrado TEXT,
    telefono_cifrado TEXT,
    direccion_cifrada TEXT,
    age INT,
    job VARCHAR(50),
    marital VARCHAR(30),
    education VARCHAR(30),
    default_credit VARCHAR(5),
    balance NUMERIC(12,2),
    housing VARCHAR(5),
    loan VARCHAR(5),
    contact VARCHAR(30),
    day INT,
    month VARCHAR(10),
    duration INT,
    campaign INT,
    pdays INT,
    previous INT,
    poutcome VARCHAR(30),
    deposit VARCHAR(5)
);

```

```

CREATE TABLE consentimiento (
    consentimiento_id UUID PRIMARY KEY,
    cliente_id UUID NOT NULL REFERENCES cliente(cliente_id),
    estado VARCHAR(20) NOT NULL CHECK
        (estado IN ('opt-in', 'opt-out', 'no informado')),
    canal VARCHAR(30),
    fecha_registro TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
    fecha_actualizacion TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
    actualizado_por UUID REFERENCES usuario(usuario_id)
);

```

```

CREATE TABLE campania (
    campania_id UUID PRIMARY KEY,
    nombre VARCHAR(120) NOT NULL,
    producto VARCHAR(80) NOT NULL,
    fecha_inicio DATE NOT NULL,
    fecha_fin DATE,
    estado VARCHAR(30) NOT NULL CHECK
        (estado IN ('planificada', 'activa', 'cerrada', 'cancelada'))
);

```

```

);

CREATE TABLE asignacion (
    asignacion_id UUID PRIMARY KEY,
    cliente_id UUID NOT NULL REFERENCES cliente(cliente_id),
    campania_id UUID NOT NULL REFERENCES campania(campania_id),
    usuario_id UUID NOT NULL REFERENCES usuario(usuario_id),
    estado_contacto VARCHAR(30) DEFAULT 'pendiente',
    fecha_asignacion TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);

CREATE TABLE resultado_contacto (
    resultado_id UUID PRIMARY KEY,
    asignacion_id UUID NOT NULL REFERENCES asignacion(asignacion_id),
    resultado VARCHAR(40) NOT NULL,
    observacion TEXT,
    fecha_contacto TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);

CREATE TABLE audit_log (
    log_id UUID PRIMARY KEY,
    usuario_id UUID REFERENCES usuario(usuario_id),
    accion VARCHAR(100) NOT NULL,
    recurso VARCHAR(100) NOT NULL,
    recurso_id VARCHAR(100),
    ip_origen VARCHAR(45),
    resultado VARCHAR(30) NOT NULL,
    detalle TEXT,
    timestamp_evento TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);

```

9.4. Requerimientos funcionales

Los requerimientos funcionales describen las capacidades que debe cumplir el sistema desde la perspectiva del usuario y del negocio. Para priorizarlos se utiliza el criterio MoSCoW: Must, Should, Could y Won't.

En conjunto, estos requerimientos permiten cubrir el funcionamiento principal del sistema y preparan la base para el Bloque IV, donde se detallarán los requerimientos de seguridad, privacidad, cifrado, auditoría, gestión de consentimiento, respaldo y respuesta ante incidentes.

10. Bloque IV — Seguridad y privacidad

Este bloque presenta las medidas de seguridad y privacidad consideradas para el sistema. Debido a que la plataforma trabaja con información personal y financiera de clientes, se propone una estrategia basada en múltiples capas de protección. Las medidas incluyen protección de datos almacenados y en tránsito, control de accesos, gestión de consentimiento, auditoría de eventos y procedimientos de respuesta ante incidentes.

10.1. Protección de datos en reposo

10.1.1. Cifrado de información sensible

Los datos considerados sensibles, como nombre, DNI, correo electrónico, teléfono y dirección, se almacenan cifrados utilizando AES-256 en modo GCM. Este modo permite asegurar tanto la confidencialidad como la integridad de la información almacenada. Las claves de cifrado no se guardan dentro de la base de datos, sino como variables de entorno protegidas en el servidor.

En el frontend, la visualización de esta información depende del rol del usuario autenticado. Por ejemplo, un teleoperador solo puede visualizar parcialmente ciertos datos del cliente, mientras que perfiles analíticos trabajan únicamente con información agregada. Esto permite aplicar el principio de mínimo acceso y reducir la exposición innecesaria de datos personales.

10.1.2. Hashing de contraseñas

Las contraseñas de usuarios internos no se almacenan en texto plano. Para su protección se utiliza Argon2id, algoritmo recomendado actualmente para almacenamiento seguro de credenciales debido a su resistencia frente a ataques por fuerza bruta y ataques acelerados por GPU.

A diferencia de algoritmos rápidos como SHA-256, Argon2id está diseñado para requerir más tiempo y memoria durante el proceso de hash, dificultando ataques masivos sobre contraseñas filtradas. Además, cada contraseña utiliza un *salt* aleatorio único generado para cada usuario.

La implementación propuesta es la siguiente:

```
from passlib.hash import argon2

password_hash = argon2.using(
    memory_cost=65536,
    time_cost=3,
    parallelism=1
).hash(raw_password)

is_valid = argon2.verify(raw_password, stored_hash)
```

Asimismo, las comparaciones de credenciales se realizan utilizando funciones de tiempo constante para evitar ataques de temporización.

10.1.3. Política de respaldos

El sistema considera una política de respaldos cifrados para reducir el riesgo de pérdida de información. La información se encuentra en la tabla 14

Los respaldos se almacenan en una ubicación separada del servidor principal y las claves de descifrado se mantienen en un entorno independiente. Además, periódicamente se realizan pruebas de restauración para verificar la integridad de los respaldos.

10.2. Protección de datos en tránsito

Toda comunicación entre cliente y servidor se realiza mediante HTTPS utilizando TLS 1.2 o superior. El servidor Nginx actúa como proxy reverso y centraliza la configuración TLS.

Para el entorno académico se utilizan certificados autofirmados generados con OpenSSL:

```
openssl genrsa -out server.key 2048
```

```
openssl req -new -key server.key -out server.csr \  
-subj "/C=PE/ST=Lima/O=BancoProyecto/CN=localhost"
```

```
openssl x509 -req -days 365 -in server.csr \  
-signkey server.key -out server.crt
```

El uso de TLS evita que credenciales, información de clientes o resultados de campañas puedan ser interceptados o modificados durante la transmisión. En un entorno productivo, los certificados autofirmados deberían reemplazarse por certificados emitidos por una autoridad certificadora reconocida.

10.3. Control de accesos basado en roles

El sistema implementa un modelo RBAC (*Role-Based Access Control*), donde los permisos se asignan a roles y posteriormente a usuarios. Este enfoque facilita la administración de permisos y mejora la trazabilidad de accesos. Esta información se puede observar en la tabla 15.

La validación de permisos se realiza desde el backend antes de ejecutar cada endpoint. Si un usuario intenta acceder a un recurso no autorizado, el sistema devuelve un error HTTP 403 y registra el evento en el log de auditoría.

10.4. Gestión del consentimiento

El consentimiento del cliente es obligatorio para cualquier campaña de contacto. El sistema considera tres estados posibles:

- **opt-in**: el cliente autoriza comunicaciones.
- **opt-out**: el cliente rechaza ser contactado.
- **no informado**: no existe una decisión registrada.

Las consultas de clientes elegibles filtran automáticamente aquellos usuarios que no hayan otorgado consentimiento. De esta forma, los clientes con estado **opt-out** no aparecen disponibles para campañas ni asignaciones.

Además, cualquier cambio en el estado de consentimiento queda registrado en el sistema para mantener trazabilidad.

10.5. Registros de auditoría

El sistema mantiene registros de eventos relevantes en la tabla 16. Estos registros permiten monitorear accesos y detectar actividades sospechosas.

Los eventos de prioridad alta son revisados periódicamente para identificar patrones anómalos, como múltiples intentos fallidos de autenticación o accesos fuera del horario habitual.

10.6. Plan de respuesta ante incidentes

El sistema considera un plan básico de respuesta ante incidentes inspirado en la guía NIST SP 800-61. El proceso contempla cinco etapas: preparación, detección, contención, recuperación y revisión posterior. Para poder tener más detalle se encuentra en la tabla 17

Ante un incidente crítico, las acciones inmediatas incluyen bloqueo de cuentas comprometidas, revocación de sesiones activas y aislamiento temporal del servicio afectado.

Posteriormente, se identifican las causas del incidente y se aplican las correcciones necesarias antes de restaurar el sistema.

10.7. Estrategias de uso seguro

10.7.1. Política de contraseñas

La política de contraseñas propuesta considera:

- Longitud mínima de 12 caracteres.
- Verificación contra listas de contraseñas comprometidas.
- Bloqueo temporal tras múltiples intentos fallidos.
- Cambio obligatorio únicamente si existe sospecha de compromiso.

10.7.2. Capacitación del personal

El personal con acceso al sistema debe recibir capacitación básica en:

- Identificación de phishing.
- Prevención de ingeniería social.
- Uso seguro de sesiones.
- Reporte de incidentes o accesos sospechosos.

10.8. Recomendaciones futuras

Como mejoras futuras para el sistema se consideran las siguientes medidas:

1. Implementación de un sistema SIEM para monitoreo centralizado de logs.
2. Uso de un KMS o HSM para gestión segura de claves.
3. Incorporación de autenticación multifactor (MFA).
4. Migración a certificados emitidos por una CA pública.
5. Evaluación de modelos ABAC para escenarios con restricciones contextuales.
6. Aplicación de técnicas de privacidad diferencial en reportes agregados.

11. Bloque V — Próximos pasos

En este bloque se presentan las actividades pendientes para completar el desarrollo del sistema, así como las pruebas y elementos que serán considerados en la entrega final del proyecto.

11.1. Implementación del prototipo

Para finalizar el prototipo se plantean las siguientes actividades principales:

1. **Carga de datos y generación de información sintética:** se realizará la carga del *Bank Marketing Dataset* y la generación de datos sintéticos utilizando **Faker**. Con ello se poblarán las tablas del modelo relacional en PostgreSQL, incluyendo usuarios internos, roles, permisos, consentimientos y campañas de prueba.
2. **Implementación de autenticación y autorización:** en el backend desarrollado con FastAPI se implementará el sistema de login utilizando JWT, además de la validación de permisos según el rol de cada usuario. También se integrará el registro automático de eventos en el sistema de auditoría.
3. **Desarrollo de endpoints principales:** se implementarán los endpoints asociados a los principales casos de uso del sistema, como consulta de clientes elegibles, asignación de clientes a teleoperadores, registro de resultados de contacto y actualización de consentimientos.
4. **Configuración de HTTPS:** se configurará Nginx como proxy reverso utilizando certificados TLS autofirmados generados mediante OpenSSL, asegurando que la comunicación con el sistema se realice mediante HTTPS.
5. **Desarrollo del frontend:** se implementarán interfaces básicas para cada rol del sistema (administrador, supervisor, analista y teleoperador). El objetivo principal será demostrar el funcionamiento del control de acceso y las restricciones de permisos.
6. **Validación del sistema de auditoría:** se ejecutarán diferentes acciones de prueba para comprobar que eventos importantes, como inicios de sesión, modificaciones de consentimiento o accesos no autorizados, sean registrados correctamente en la tabla 16.

11.2. Pruebas de seguridad

Antes de la entrega final se realizarán pruebas básicas de seguridad para verificar el correcto funcionamiento de los controles implementados.

- **Control de acceso:** verificar que cada usuario únicamente pueda acceder a las funciones permitidas según su rol. Por ejemplo, un teleoperador no debe acceder a funciones administrativas ni visualizar clientes que no le fueron asignados.
- **Validación del consentimiento:** comprobar que los clientes con estado **opt-out** no aparezcan como elegibles en ninguna campaña.
- **Autenticación:** validar el bloqueo temporal tras múltiples intentos fallidos de login y verificar que las contraseñas estén almacenadas como hashes Argon2id.

- **Protección en tránsito:** comprobar que el sistema funcione únicamente mediante HTTPS y que el certificado TLS sea reconocido correctamente.
- **Prevención de inyección SQL:** verificar que las consultas a base de datos utilicen parámetros seguros y que entradas maliciosas no produzcan comportamientos inesperados.

11.3. Documentación final

Para la entrega final tenemos planeado que incluya, además del informe, los siguientes elementos:

- Código fuente del prototipo y guía de instalación.
- Repositorio GitHub con el proyecto organizado.
- Capturas de pantalla o demostraciones del sistema funcionando según cada rol.
- Resultados de las pruebas realizadas.
- Reflexión final del equipo sobre el proceso de diseño e implementación del sistema.

11.4. Referencias

Referencias

- Anderson, R. J. (2020). *Security Engineering: A Guide to Building Dependable Distributed Systems* (3.^a ed.). Wiley.
- Bachmann, J. (2018). Bank Marketing Dataset [Consultado: mayo 2026]. <https://www.kaggle.com/datasets/janiobachmann/bank-marketing-dataset>
- Biryukov, A., Dinu, D., & Khovratovich, D. (2015). Argon2: The Memory-Hard Function for Password Hashing and Other Applications [Consultado: mayo 2026]. <https://www.password-hashing.net/argon2-specs.pdf>
- Congreso de la República del Perú. (2011). Ley N.º 29733, Ley de Protección de Datos Personales [Consultado: mayo 2026]. <https://www.gob.pe/institucion/congreso-de-la-republica/normas-legales/243470-29733>
- Ministerio de Justicia y Derechos Humanos del Perú. (2024). Decreto Supremo N.º 016-2024-JUS, Reglamento de la Ley de Protección de Datos Personales [Consultado: mayo 2026]. <https://www.gob.pe/institucion/minjus/normas-legales/6167815-016-2024-jus>
- Moro, S., Cortez, P., & Rita, P. (2014). A data-driven approach to predict the success of bank telemarketing. *Decision Support Systems*, 62, 22-31. <https://doi.org/10.1016/j.dss.2014.03.001>
- National Institute of Standards and Technology. (2012). Computer Security Incident Handling Guide (SP 800-61r2) [Consultado: mayo 2026]. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>
- National Institute of Standards and Technology. (2020). Digital Identity Guidelines: Authentication and Lifecycle Management (SP 800-63B) [Consultado: mayo 2026]. <https://pages.nist.gov/800-63-3/sp800-63b.html>
- OWASP Foundation. (2021). OWASP Top Ten 2021 [Consultado: mayo 2026]. <https://owasp.org/www-project-top-ten/>
- OWASP Foundation. (2024). Password Storage Cheat Sheet [Consultado: mayo 2026]. https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html

11.5. Anexos

Dato	Clasificación	Tratamiento propuesto
DNI, teléfono, email, dirección	Dato personal identificable	Cifrado a nivel de aplicación o columna. Visualización enmascarada según rol.
Nombre completo	Dato personal	Acceso restringido y registro de consulta en auditoría.
Balance, default, housing, loan	Dato financiero	Acceso limitado a roles autorizados. Cifrado o enmascaramiento parcial.
Password de usuario interno	Credencial sensible	Almacenamiento solo como hash usando Argon2id o bcrypt.
Estado de consentimiento	Dato de privacidad	Trazabilidad de cambios y bloqueo automático de campañas si existe opt-out.
Logs de auditoría	Evidencia de seguridad	Protección contra modificación no autorizada y retención definida.

Cuadro 12: Clasificación de columnas sensibles y tratamiento propuesto.

ID	Descripción	Prioridad	Criterio de aceptación
RF-01	El sistema debe permitir el inicio de sesión de usuarios internos mediante credenciales válidas.	Must	Un usuario registrado puede autenticarse y acceder a las funciones permitidas por su rol.
RF-02	El sistema debe validar el rol del usuario autenticado antes de mostrar módulos o datos.	Must	Un teleoperador no puede acceder a funciones administrativas ni a clientes no asignados.
RF-03	El administrador debe poder crear, editar, activar y desactivar usuarios internos.	Must	Los cambios en usuarios se guardan correctamente y generan un evento de auditoría.
RF-04	El administrador debe poder asignar roles a usuarios internos.	Must	Cada usuario queda asociado a un único rol activo dentro del sistema.
RF-05	El sistema debe permitir registrar y administrar campañas comerciales.	Must	Una campaña puede crearse con nombre, producto, fechas y estado.
RF-06	El sistema debe listar clientes elegibles para una campaña según criterios comerciales y estado de consentimiento.	Must	Los clientes con opt-out no aparecen en la lista de elegibles.
RF-07	El analista de marketing debe poder visualizar perfiles priorizados para una campaña activa.	Must	La lista muestra clientes filtrados y ordenados según reglas de priorización o scoring simulado.
RF-08	El supervisor debe poder asignar clientes elegibles a teleoperadores.	Must	Cada asignación vincula cliente, campaña y teleoperador responsable.
RF-09	El teleoperador debe visualizar únicamente los clientes que le fueron asignados.	Must	Al consultar su bandeja, el teleoperador no accede a clientes de otros usuarios.
RF-10	El teleoperador debe registrar el resultado del contacto realizado.	Must	El resultado queda asociado a la asignación, fecha, usuario y campaña.
RF-11	El sistema debe permitir actualizar el estado de consentimiento del cliente.	Must	Un cambio de opt-in a opt-out excluye al cliente de futuras campañas.
RF-12	El supervisor debe consultar métricas agregadas de campaña.	Should	El sistema muestra tasa de conversión, llamadas efectivas, llamadas no efectivas y opt-out.
RF-13	El sistema debe registrar en auditoría los accesos a información sensible.	Must	Cada consulta de datos sensibles genera un registro con usuario, acción, recurso, IP y timestamp.
RF-14	El sistema debe permitir búsquedas filtradas de clientes por campaña, estado de contacto y resultado.	Should	El usuario autorizado puede aplicar filtros sin visualizar datos fuera de su permiso.
RF-15	El sistema debe permitir exportar reportes únicamente a usuarios autorizados.	Could	Solo roles permitidos pueden exportar reportes y cada exportación queda registrada en auditoría.
RF-16	El sistema debe mostrar mensajes de error controlados ante accesos no autorizados.	Must	Un intento de acceso indebido devuelve un mensaje genérico y queda registrado en logs.

Tipo	Frecuencia	Retención	Cifrado
Respaldo completo	Semanal	4 semanas	AES-256-GCM
Respaldo incremental	Diario	7 días	AES-256-GCM
Respaldo de logs	Diario	90 días	AES-256-GCM

Cuadro 14: Política de respaldos del sistema.

Recurso / Acción	Admin	Supervisor	Analista	Teleoperador
Clientes — ver datos sensibles	Sí	Sí	Parcial	Solo asignados
Clientes — exportar	Sí	Sí	No	No
Campañas — crear/editar	Sí	Sí	No	No
Campañas — consultar	Sí	Sí	Sí	Solo asignadas
Resultados — registrar	No	No	No	Sí
Usuarios internos — gestionar	Sí	No	No	No
Logs de auditoría — consultar	Sí	Sí	No	No

Cuadro 15: Matriz simplificada de permisos RBAC.

Evento	Prioridad	Datos registrados
Inicio de sesión exitoso	Media	usuario, IP, timestamp
Intento de login fallido	Alta	usuario, IP, timestamp
Acceso a datos sensibles	Alta	usuario, cliente, acción
Modificación de consentimiento	Alta	usuario, cambio realizado
Exportación de datos	Alta	usuario, recurso exportado
Acceso denegado (403)	Alta	usuario, recurso solicitado

Cuadro 16: Eventos auditados por el sistema.

Nivel	Descripción	Ejemplo	Tiempo respuesta
P1	Fuga confirmada de datos	Acceso externo a la BD	< 4 horas
P2	Acceso no autorizado interno	Uso indebido de permisos	< 24 horas
P3	Actividad sospechosa	Intentos fallidos repetidos	< 72 horas

Cuadro 17: Clasificación de incidentes.